# INFORMATION MANAGEMENT FRAMEWORK

*[Company Name] | Overarching Framework Document*

**Document ID:** IMF-001
**Version:** 1.0 — DRAFT
**Classification:** Internal Use
**Owner:** Chief Information Officer
**Effective Date:** [DATE]
**Review Date:** [DATE + 1 Year]

**CONFIDENTIAL — FOR INTERNAL USE ONLY**

# Document Control

| Field | Detail |
|---|---|
| Document Title | Information Management Framework |
| Document ID | IMF-001 |
| Version | 1.0 — DRAFT |
| Status | Draft for Review |
| Document Owner | Chief Information Officer |
| Custodian | Information Security / IT Governance |
| Effective Date | [DATE] |
| Next Review Date | [DATE + 1 Year] |
| Regulatory Alignment | ISO 27001, NIST CSF, GxP, SOX, 21 CFR Part 11 |

## Revision History

| Version | Date | Author | Description |
|---|---|---|---|
| 0.1 | [DATE] | [Author] | Initial draft |
| 1.0 | [DATE] | [Author] | Issued for review |

# 1. Purpose

This Information Management Framework (IMF) establishes the overarching structure, principles, and classification schema that govern how [Company Name] manages its information assets and technology systems. It is the authoritative reference document for all information-related policies, standards, procedures, and work instructions.

The IMF does not prescribe operational controls directly. Instead, it:

- Defines the classification schema for data sensitivity and system criticality
- Establishes the governance model and accountability structure
- Provides the regulatory and standards context in which all subordinate documents operate
- Mandates that specific Policies, SOPs, and Work Instructions exist and remain current
- Serves as the entry point for internal and external audit review of information governance

This framework applies to all information assets owned, processed, stored, or transmitted by [Company Name], including those managed by third parties on the company's behalf.

# 2. Scope

This framework applies to:

- All employees, contractors, and third-party personnel who access or manage company information assets
- All data created, received, stored, transmitted, or processed by or on behalf of [Company Name]
- All information systems and technology infrastructure, whether on-premises, cloud-hosted, or hybrid
- All geographic locations and business units within the [Company Name] corporate group

Exclusions: Public domain information with no proprietary association is excluded from classification requirements but remains subject to applicable regulatory obligations.

# 3. Guiding Principles

The following principles underpin all information management activities at [Company Name]:

| Principle | Description |
|---|---|
| Data Integrity | Information must be accurate, complete, consistent, and trustworthy throughout its lifecycle. All GxP data must conform to ALCOA+ standards: Attributable, Legible, Contemporaneous, Original, Accurate, and Complete. |
| Least Privilege | Access to information is granted on a need-to-know basis, to the minimum extent required to fulfil a legitimate business function. |
| Classification-Driven Controls | The level of control applied to any data asset or system is derived from its classification. Controls are proportionate to risk. |
| Risk-Based Prioritisation | Resources and controls are prioritised according to the sensitivity and criticality of assets, with highest-risk assets receiving the greatest level of protection. |
| Regulatory Compliance | All information management activities must comply with applicable regulatory requirements. Where multiple regulations apply, the most stringent requirement governs. |
| Accountability | All data and systems have a designated owner who is accountable for appropriate classification, access management, and periodic review. |
| Continuous Improvement | This framework and its subordinate documents are reviewed at least annually, and whenever material regulatory, organisational, or technological changes occur. |

# 4. Classification Schema

All information assets and systems at [Company Name] are classified across two independent axes: Sensitivity and Criticality. These axes are always assessed separately.

## 4.1 Data Sensitivity

Data Sensitivity describes the confidentiality risk associated with unauthorised disclosure of information. All data must be assigned one of the following sensitivity tiers:

| Tier | Label | Description | Examples |
|---|---|---|---|
| 1 | Public | Information approved for unrestricted external distribution. | Press releases, published reports, public website content |
| 2 | Business Use | General internal information not intended for public disclosure but carrying no special regulatory obligation. | Internal memos, project plans, standard operating procedures |
| 3 | Sensitive | Information whose disclosure could cause reputational, financial, or operational harm. | Business strategies, financial forecasts, commercial contracts |
| 4 | Sensitive Personal | Personal data as defined under applicable privacy regulation (GDPR, HIPAA, CCPA). Subject to heightened regulatory obligation. | Employee records, patient data, clinical trial subject data |
| 5 | Highly Confidential | The most sensitive category. Disclosure could cause severe business, regulatory, or legal consequences. | Trade secrets, M&A information, regulatory submission data, cryptographic keys |

## 4.2 System Criticality

System Criticality describes the operational impact of a system becoming unavailable or compromised. Criticality is assessed independently of the sensitivity of the data the system holds, using two separate inputs that are then reconciled to a final classification:

| Input | Question Asked |
|---|---|
| Data-Derived Criticality | What is the business impact of the data this system stores or processes becoming unavailable or corrupted? |
| Functional Criticality | What is the operational impact of this system being unavailable, regardless of the sensitivity or criticality of its data? |

Rule: A system's final criticality classification is the higher of its data-derived criticality and its functional criticality.

Example: A DNS infrastructure system holds no sensitive or business-critical data. However, its failure would cause an immediate, company-wide operational outage. It is therefore classified as Extremely Critical on functional grounds, notwithstanding its low data criticality.

| Tier | Label | Functional Criteria | RPO Target | RTO Target |
|---|---|---|---|---|
| 1 | Extremely Critical | Failure causes immediate, company-wide operational outage or regulatory breach. No workaround exists. | < 1 hour | < 4 hours |
| 2 | Critical | Failure significantly degrades operations within hours. Limited workaround may exist. | < 4 hours | < 24 hours |
| 3 | Standard | Failure affects specific functions but does not impair core operations. Workaround available. | < 24 hours | < 72 hours |
| 4 | None | Failure has negligible operational impact. Can remain offline for extended periods. | Best effort | Best effort |

## 4.3 Classification Governance

- Every data asset and system must be classified at creation or onboarding and reviewed at least annually.
- The Data Owner is responsible for assigning and maintaining the classification of data assets.
- The System Owner is responsible for assigning and maintaining system criticality, with input from the IT and Security functions.
- Where classification is uncertain, the owner must escalate to the Information Security function for adjudication.
- Classification must be documented in the corporate Asset Register.

# 5. Regulatory & Standards Alignment

This framework is designed to satisfy, or provide the governance foundation for satisfying, the following regulatory and industry standards. Detailed compliance mapping is maintained by the Compliance function and reviewed annually.

| Regulation / Standard | Applicability | Primary Domain |
|---|---|---|
| ISO/IEC 27001:2022 | Company-wide | Information security management system structure and controls |
| NIST Cybersecurity Framework (CSF) | Company-wide | Cybersecurity risk management; board-level reporting language |
| 21 CFR Part 11 | GxP systems holding electronic records and signatures | Electronic records integrity, audit trails, e-signatures |
| EU Annex 11 | EU-facing GxP computerised systems | Computerised system validation and controls |
| GxP (broad) | R&D, manufacturing, QA functions | Data integrity, ALCOA+ compliance |
| SOX (Sarbanes-Oxley) | Financial reporting systems | IT general controls, access management, change management, audit trails |
| HIPAA | Systems processing US patient health information | Protected health information controls |
| GDPR | Processing of EU personal data | Data classification, retention, subject rights, breach notification |
| CCPA | Processing of California consumer personal data | Consumer rights, data inventory, disclosure obligations |

# 6. Governance Model

## 6.1 Roles and Responsibilities

| Role | Responsibility |
|---|---|
| Board / Audit Committee | Ultimate oversight of information risk. Receives periodic reporting on information risk posture via the CISO. |
| Chief Information Officer (CIO) | Framework Owner. Accountable for the existence, currency, and effectiveness of this IMF and its subordinate document set. |
| Chief Information Security | Accountable for the information security control environment. Chairs |

| Role | Responsibility |
|---|---|
| Officer (CISO) | the Information Security Steering Group. |
| Data Protection Officer (DPO) | Accountable for privacy regulation compliance. Advises on classification of personal data. |
| Data Owners | Business unit leaders accountable for the classification, accuracy, and appropriate use of data within their domain. |
| System Owners | Technical or business owners accountable for the classification, lifecycle, and controls applied to specific systems. |
| IT / Information Security | Responsible for implementing and operating controls mandated by this framework and its subordinate policies. |
| All Personnel | Responsible for handling information in accordance with its classification and applicable policies. |

## 6.2 Information Security Steering Group (ISSG)

The ISSG is the governing body responsible for oversight of this framework. It meets quarterly and is responsible for:

- Reviewing and approving changes to the IMF and top-level Policies
- Reviewing the annual information risk register
- Monitoring compliance with this framework across the organisation
- Escalating material information risk items to the Board

# 7. Document Hierarchy

All information management documentation at [Company Name] operates within the following hierarchy. Each level inherits and operationalises the layer above it. Conflicts between levels are resolved in favour of the higher-level document, unless the higher-level document explicitly grants discretion to the lower level.

| Level | Type | Purpose | Owned By | Review Cycle |
|---|---|---|---|---|
| 0 | Framework (IMF) | Defines schema, principles, governance, and document architecture. Not a control document. | CIO | Annual |
| 1 | Policy (POL) | Mandates what must happen and why. States requirements and assigns accountability. | Senior Leadership / CISO | Annual |
| 2 | Standard Operating Procedure (SOP) | Defines how a Policy requirement is operationalised. Process-level. | Function Heads | Annual or on change |
| 3 | Work Instruction (WI) | Step-by-step instructions for executing a specific task within an SOP. | Process Owners / IT | On change |

## 7.1 Mandated Policy Documents

The following Policies are mandated by this Framework. Each must exist, be approved, and be maintained in current form:

| Policy ID | Policy Title | Primary Regulation(s) |
|---|---|---|
| POL-001 | Data Classification Policy | ISO 27001, GDPR, HIPAA |
| POL-002 | Data Retention & Disposal Policy | GDPR, SOX, GxP |
| POL-003 | Data Integrity Policy | GxP, 21 CFR Part 11, Annex 11 |
| POL-004 | Privacy Policy | GDPR, HIPAA, CCPA |
| POL-005 | System Classification Policy | ISO 27001, GxP, SOX |
| POL-006 | Computer System Validation Policy | 21 CFR Part 11, Annex 11, GxP |
| POL-007 | Change Management Policy | SOX, ISO 27001, GxP |
| POL-008 | Access Control Policy | ISO 27001, SOX, HIPAA |
| POL-009 | Privileged Access Management Policy | ISO 27001, SOX |
| POL-010 | Information Security Risk Policy | ISO 27001, NIST CSF |

| Policy ID | Policy Title | Primary Regulation(s) |
|---|---|---|
| POL-011 | Business Continuity Policy | ISO 27001, GxP, SOX |
| POL-012 | Incident Response Policy | ISO 27001, GDPR, HIPAA |
| POL-013 | Third Party & Vendor Risk Policy | ISO 27001, GDPR, SOX |
| POL-014 | Audit Trail & Monitoring Policy | GxP, 21 CFR Part 11, SOX |

# 8. Framework Review & Maintenance

This framework is a living document. It must be reviewed and, where necessary, updated in the following circumstances:

- Annually, as part of the scheduled ISSG review cycle
- Following any material change in applicable regulatory requirements
- Following a significant organisational change (acquisition, divestiture, major system implementation)
- Following a significant information security incident or audit finding

All amendments to this framework require approval by the CIO and ratification by the ISSG before taking effect. Version history is maintained in the Document Control table at Section 1.

# 9. Definitions

| Term | Definition |
|---|---|
| ALCOA+ | Data integrity standard: Attributable, Legible, Contemporaneous, Original, Accurate, and Complete. |
| Asset Register | The central inventory of all data assets and information systems, including their classification and ownership. |
| Criticality | The operational impact of a system becoming unavailable or compromised, independent of data sensitivity. |
| CSV / CSA | Computer System Validation / Computer Software Assurance: regulatory processes for qualifying systems used in GxP activities. |
| Data Owner | The business leader accountable for a data domain, including its classification and appropriate use. |
| GxP | The collective term for Good Practice regulations applicable to life-sciences (GMP, GLP, GCP, GDP, etc.). |
| IAM | Identity and Access Management: the framework of controls governing who |

| Term | Definition |
|---|---|
| | can access what resources. |
| RPO | Recovery Point Objective: the maximum acceptable age of recovered data following a system failure. |
| RTO | Recovery Time Objective: the maximum acceptable duration of a system outage before recovery must be achieved. |
| Sensitivity | The confidentiality risk associated with unauthorised disclosure of a data asset. |
| System Owner | The individual accountable for the lifecycle, classification, and controls applied to a specific system. |

# 10. Related Documents

The following documents are directly related to this framework and should be read in conjunction with it:

| Document ID | Title | Relationship |
|---|---|---|
| POL-001 through POL-014 | See Section 7.1 | Mandated by this Framework |
| REG-001 | Regulatory Compliance Register | Referenced by Section 5 |
| RISK-001 | Information Risk Register | Maintained in accordance with Section 6 |
| ASSET-001 | Corporate Asset Register | Maintained in accordance with Section 4.3 |

*— End of Document —*

IMF-001 v1.0 DRAFT | [Company Name] | CONFIDENTIAL